IIT Roorkee × Futurense

PG Certificate Program in AI/GenAI Powered Cybersecurity

Capstone Project — Cohort 1

PipelineFortress — Secure CI/CD with GenAI-Assisted Triage

Field	Detail
EC-Council Track	**DevSecOps Essentials (DSE)**
Project Code	`CAP-DSE-3W`
Mode	Individual **or** Team (2–4 members)
Duration	**3 weeks** (~35–40 hours of effort)
Difficulty	Foundational → Intermediate (industry-aligned)
Delivery Mode	Hands-on lab + written report + oral defense
Program	PG Certificate in AI/GenAI Powered Cybersecurity, IIT Roorkee × Futurense

---

1. Project Overview

Students take a deliberately vulnerable web application and wrap it in a CI/CD pipeline with security stages — SAST, SCA, secrets scanning, IaC scanning, and a basic DAST step. They then build a GenAI assistant that triages findings, drafts remediation Pull Requests, and (critically) refuses to act on anything that looks like a secret or a hallucination.

2. Real-World Problem Statement

An e-commerce engineering team ships 30+ times a day. Their current security reviews happen at the end of each sprint and block releases. The CISO wants a shift-left pipeline that catches 80% of vulnerabilities before merge, with developer-friendly feedback. You are the small platform-security team prototyping the reference pipeline.

3. Key Learning Outcomes

- Apply the DevSecOps maturity model and shift-left principles.
- Integrate SAST, SCA, secrets, IaC, and DAST tooling into a CI/CD pipeline.
- Build secure container images and generate SBOMs.
- Use an LLM to summarize and triage findings safely.
- Measure pipeline impact (true positives, false positives, developer-feedback time).

4. Tools and Technologies

Layer	Tools
Pipeline	GitHub Actions (default) or GitLab CI
Vulnerable target	OWASP Juice Shop
SAST	Semgrep (default) or SonarQube
SCA + container	Trivy + Syft (for SBOM)
Secrets scanning	gitleaks
IaC scanning	Checkov
DAST	OWASP ZAP (baseline scan)
Runtime (optional)	Falco on a kind cluster
LLM	An LLM via API, with a strict redaction layer
Reporting	Markdown / PDF

5. Phased Plan — 3 Weeks

Week 1 — Baseline Pipeline (~12 hours)

1. Fork OWASP Juice Shop into a repo and write a baseline pipeline that builds, tests, and deploys to a local kind cluster.
2. Document the baseline vulnerabilities at runtime.
3. Add SAST (Semgrep), SCA (Trivy), and secrets scanning (gitleaks) stages with sensible severity gates.

Week 1 deliverable: Working pipeline + baseline vulnerability report.

Week 2 — Shift-Left Coverage (~14 hours)

1. Add IaC scanning (Checkov) and container scanning (Trivy on the built image).
2. Generate an SBOM (Syft).
3. Add a ZAP baseline DAST scan against the deployed staging environment.
4. Build a metrics dashboard: vulnerabilities introduced, vulnerabilities caught, by stage.

Week 2 deliverable: Full multi-stage pipeline + SBOM + metrics dashboard.

Week 3 — GenAI Triage (~12 hours)

1. Build the LLM triage tool. Inputs: consolidated scanner JSON. Outputs: clustered duplicates, prioritized list, suggested fix in 3–5 lines.
2. Implement the redaction layer: strip secrets, source-code blocks, and proprietary identifiers before any prompt ever leaves the build runner.
3. For the top-3 findings, have the LLM draft a fix and submit it as a Pull Request that a human must approve.
4. Final report with honest false-positive/false-negative analysis of the LLM triage.

Week 3 deliverable: LLM triage tool + 3 sample auto-generated PRs + final report.

6. Final Deliverables

- Hardened CI/CD pipeline (YAML).
- Policy-as-code rules (Checkov/OPA).
- Hardened container image with SBOM (Syft output).
- LLM triage tool + redaction layer + prompt library.
- 3 auto-generated remediation PRs (and your review notes on each).
- Metrics dashboard.
- 12–15 page final report including DevSecOps maturity self-assessment.

7. Evaluation Rubric

Criterion	Weight	What "Excellent" Looks Like
Pipeline coverage	20%	All five stages working with sensible gates
Container + IaC hardening	15%	Image scanned, SBOM generated, IaC compliant with CIS
LLM triage soundness	20%	Honest FP/FN analysis, no hallucinated CVEs
Redaction layer	10%	Verified: no secrets/source code reach the LLM
Sample PRs	10%	At least one PR is actually correct on first review
Metrics + dashboard	10%	Useful, not vanity metrics
Report + oral defense	15%	Tight, evidence-based
Total	**100%**	

8. Mode: Individual vs Team Scope

Aspect	Individual	Team (2–4)
Pipeline stages	4 (SAST, SCA, secrets, container)	5 (above + DAST) + optional runtime
Vulnerable app	OWASP Juice Shop only	Juice Shop + one small custom microservice
Auto-generated PRs	2	4
Report length	10–12 pages	14–18 pages

9. Estimated Duration

3 weeks, approximately 35–40 hours per learner.

10. Difficulty Level

Intermediate. Some prior Git/CI familiarity assumed. The redaction layer is the highest-leverage learning experience in the project — it forces students to think carefully about what data should and should not flow to an external LLM.

11. Suggested Stretch Goals (Optional)

- Add Falco on a kind cluster and forward alerts to a small SIEM stub.
- Implement a "policy bot" using the LLM that explains *why* a Checkov rule failed, in plain English, in each PR.

---

12. Ethics, Safety, and Responsible Use

- All offensive activity, scanning, or exploitation must be confined to the lab or instructor-provided sandbox. No real-world targets.
- Any use of GenAI / LLMs must be disclosed in the report (which model, what it was used for, how outputs were verified).
- Students must never paste real credentials, secrets, customer data, or copyrighted content into an LLM.
- All evidence and logs handled in the project remain confidential within the cohort.
- Students must sign the program's Responsible AI Use and Lab Conduct acknowledgement before starting Week 2.

13. References

- **EC-Council Essentials Series** — official module outlines and lab guides (provided via the program LMS).
- **MITRE ATT&CK** — https://attack.mitre.org
- **NIST Cybersecurity Framework 2.0** — https://www.nist.gov/cyberframework
- **OWASP Top 10** (Web / IoT / LLM) — https://owasp.org
- **CIS Benchmarks** — https://www.cisecurity.org/cis-benchmarks
- **CERT-In advisories** — https://www.cert-in.org.in